

INCIDENT INVESTIGATION REPORT

Thornbury Wealth Partners (TWP)

1. Executive Summary

The investigation confirms a coordinated, multi-stage attack spanning approximately 8 hours and 25 minutes, beginning with brute-force credential attacks against two London-based employees and culminating in ransomware deployment across the London and Toronto file servers.

Stage	Query	Time Window	Outcome
1. Initial Access	Step 1	06:00 – 06:36	2 accounts compromised
2. Priv. Escalation	Steps 2–3	09:30 – 11:30	Domain Admin granted, backdoors created
3. Exfiltration	Step 4	11:00 – 13:00	142 MB to APT C2 server
4. Impact	Step 5	14:20 – 14:25	Ransomware across 2 file servers

2. Methodology

All findings below are derived from SPL (Search Processing Language) queries executed against the security and network indexes in Splunk, with the time range set to All Time to capture the full 26 April 2026 event set. Each step builds on the previous one, narrowing from “which account was hit first” to “where did the stolen data go” and finally “when did encryption begin.”

- index=security — Windows authentication, account management, and file-access events (EventCodes 4624/4625/4720/4728/4732/4756/4663)
- index=network — Outbound/inbound traffic records including bytes transferred and destination IPs

3. Step-by-Step Breakdown

Step 1 — How Did Oliver Harrington Get Compromised?

Oliver Harrington, Senior Equities Trader in London, was the attacker's first target. This query pulls every security event tied to his username, in chronological order, to expose the full attack sequence against his account.

```
index=security user=oliver.harrington | sort _time | head 15
```

Query logic: filters the security index to events where the user field equals oliver.harrington, sorts oldest-to-newest with sort _time, and caps the output at the first 15 events with head 15 — enough to capture the full brute-force-to-compromise pattern without flooding the analyst with noise.

Field	Value	Significance
Target	oliver.harrington — Senior Equities Trader	High-value: direct access to trading systems
Attack window	06:00 – 06:08 BST	8-minute brute-force burst
Source IP	92.40.184.220	Flagged in the guide as a “UK suspicious VPN”
Pattern	8 failed logins (4625), then 1 success (4624)	Matches the SEC-002 compromise signature (≥3 failures + ≥1 success)
Risk score (SEC-002)	80	Highest of the two confirmed compromises

Step 2 — How Did James Fitzgerald Get Compromised?

The second query repeats the same pattern for James Fitzgerald, the IT Security Lead. His compromise is the more consequential of the two, since his role carries elevated trust and broader system access.

```
index=security user=james.fitzgerald | sort _time | head 15
```

Query logic: identical structure to Step 1, scoped to james.fitzgerald. Reusing the same query shape across different users is a deliberate investigative technique — it lets an analyst diff two incidents side by side using a consistent lens.

Field	Value	Significance
Target	james.fitzgerald — IT Security Lead	Compromise of a security role is catastrophic — attacker inherits elevated trust
Attack window	06:30 – 06:36 BST	6-minute burst, beginning 30 minutes after the Oliver Harrington attack
Source IP	203.0.113.77	Attributed to an APT (advanced persistent threat) actor in the guide
Pattern	6 failed logins (4625), then 1 success (4624)	Matches the SEC-002 compromise signature
Risk score (SEC-002)	60	Second-highest score; severity driven by role, not failure count

Significance: two separate source IPs (a VPN exit and a distinct APT-attributed address) successfully compromised two different accounts within 36 minutes of each other. This is consistent with a coordinated campaign rather than opportunistic, isolated attempts.

Step 3 — What Did James's Compromised Account Do Next?

With the IT Security Lead's credentials in hand, the attacker's next move is the pivot point of the entire incident. This query checks specifically whether the compromised account was used to create new accounts (4720) or escalate privileges (4728).

```
index=security user=james.fitzgerald (EventCode=4720 OR EventCode=4728) | sort _time
```

Query logic: filters to James's account specifically, then narrows to two event codes — 4720 (account created) and 4728 (added to a Global Security Group) — joined with OR inside parentheses. No head limit is applied, because every matching event here is investigatively significant.

Field	Value	Significance
Actor	james.fitzgerald (compromised)	Confirms the attacker is operating through the IT Security Lead's identity, not a separate account
Action	Promoted anthony.romano to Domain Admins	A Helpdesk Technician in New York gains domain-wide control — the single most damaging action in the chain
Time	09:30 BST	Roughly 3 hours after James's account was first compromised
Cross-reference	Matches SEC-003 (Privilege Escalation) findings	Confirms the privilege-escalation alert and this trace point to the same event

Significance: this is the moment the breach stops being a credential-theft problem and becomes a domain-control problem. Anthony Romano — a Helpdesk Technician with no business reason to hold Domain Admin rights — inherits the ability to create accounts, alter group memberships, and access nearly anything on the network, all under a legitimate-seeming approval chain since the action was performed by IT Security itself.

Step 4 — Where Did the Data Go?

With elevated access secured, the investigation turns to the network index to trace outbound traffic from the two compromised London workstations, totalling and ranking destinations by volume.

```
index=network src_ip=192.168.10.10 OR src_ip=192.168.10.15 | stats sum(bytes_out) AS total BY dest_ip | eval total_mb = round(total/1024/1024, 2) | sort -total_mb
```

Query logic: filters network traffic to the two compromised London IPs (Oliver's and James's workstations), uses stats sum(bytes_out) to total outbound bytes per destination, converts the running total from bytes to megabytes with eval and round(), then sorts highest-volume destination first with sort -total_mb.

Field	Value	Significance
Source 1	192.168.10.10 (Oliver Harrington, London)	142 MB sent to 194.165.16.11 — flagged as an APT C2 server
Source 2	192.168.10.15 (James Fitzgerald, London)	85 MB sent to the same destination, 194.165.16.11, over HTTPS (port 443)
Combined volume	227 MB from the two compromised London hosts alone	Both compromised endpoints independently exfiltrated to the same external IP, confirming a shared C2 infrastructure
Window	11:00 – 13:00 BST	2-hour exfiltration window, several hours after initial compromise — consistent with staged data collection before transfer

Field	Value	Significance
Likely contents	Client portfolio data, trading information, SWIFT-adjacent material	Per the guide's company profile, these are TWP's primary high-value targets

Note: the firm-wide SEC-004 query also flags 98 MB of SSH traffic from a third London host (192.168.10.20) and smaller transfers from New York and Toronto, suggesting exfiltration was not limited to the two accounts traced here — see Section 5 for the full picture.

Step 5 — When Did Ransomware Start, and Where?

The final trace query identifies the onset of mass file encryption by counting file-access events per minute, per host — the signature of automated, machine-speed activity rather than human behaviour.

```
index=security EventCode=4663 Object_Type=File | bucket _time span=1m | stats count BY _time, host | sort _time
```

Query logic: filters to file-access events (4663) of type File, buckets timestamps into 1-minute windows, counts events per minute per host, and sorts chronologically (oldest first) so the analyst can watch the spike emerge over time rather than seeing it pre-sorted by volume.

Field	Value	Significance
Onset	14:20 – 14:25 BST	5-minute detonation window across both affected offices
Host 1	TWP-LON-FILE01 (svc_backup)	340 file operations/minute — the worst-hit system; the compromised backup service account was the execution vector
Host 2	TWP-LON-WS-EPEMBERTON (emma.pemberton)	265 file operations/minute on the Head of Risk's workstation — identified in the guide as ransomware's point of origin
Host 3	TWP-TOR-FILE01 (svc_backup)	225 file operations/minute — confirms lateral movement reached Toronto via the same service account
Threshold logic	200+ ops/minute = malware, not human activity	No legitimate user workflow modifies 3+ files per second

Significance: the same service account, `svc_backup`, is implicated on both the London and Toronto file servers. This points to ransomware propagating through a shared, trusted automation identity rather than independent footholds on each server — a single compromised service account, used for backups, became the delivery mechanism across two countries.

4. Consolidated Attack Timeline

Synthesising all five trace queries against the alert detections (SEC-001 through SEC-007) produces the following chronology:

Time (BST)	Event
06:00–06:08	Brute force against Oliver Harrington from 92.40.184.220 — succeeds
06:30–06:36	Brute force against James Fitzgerald from APT IP 203.0.113.77 — succeeds

Time (BST)	Event
07:00–10:00	Failed brute-force attempts against CFO, Compliance Director, NY VP, and Toronto Portfolio Manager
09:30	James's compromised account promotes Anthony Romano (Helpdesk) to Domain Admins
10:00–11:30	Backdoor accounts created: temp_auditor, backdoor_admin, svc_test
11:00–13:00	142 MB+ exfiltrated from compromised London hosts to APT C2 (194.165.16.11)
14:20–14:25	Ransomware detonates via svc_backup across London and Toronto file servers

5. Key Conclusions

- Single point of entry, dual compromise: both initial breaches (Oliver Harrington, James Fitzgerald) occurred within a 36-minute window from two different external IPs, indicating a planned, parallel credential-stuffing campaign rather than opportunistic attacks.
- Trust abuse as the pivot: the most damaging single action — promoting a Helpdesk Technician to Domain Admin — was carried out using the IT Security Lead's own compromised identity, which is precisely the account least likely to be questioned.
- Shared C2 infrastructure: both traced exfiltration paths terminated at the same external IP (194.165.16.11), confirming a single attacker-controlled destination rather than separate incidents.
- Service-account weaponisation: svc_backup, a routine backup automation account, was the common thread in both the London and Toronto ransomware detonations — highlighting service accounts as a high-priority hardening target.
- Time-to-impact: From first failed login to ransomware detonation was approximately 8 hours and 25 minutes, with the most damaging stages (privilege escalation, exfiltration) occurring in the middle of the business day.

6. Recommendations

- Enforce MFA and account lockout policies on all externally reachable authentication endpoints, particularly for IT Security and trading-desk roles.
- Apply least-privilege and approval-gated workflows to any Domain Admin or Enterprise Admin group changes, regardless of which account initiates them.
- Monitor and alert on service-account behaviour (e.g., svc_backup) for activity outside its expected schedule or file-operation rate.
- Add automated network egress alerting for connections to newly observed or threat-intel-flagged destination IPs, not just volume-based thresholds.
- Review offboarding and credential-rotation procedures for FCA/SEC/OSC compliance, given the regulatory exposure created by the unauthorised Domain Admin grant and confirmed data exfiltration.

Source: *Splunk Beginner's Guide v3 — Thornbury Wealth Partners Edition, Part 10 (Bonus Investigation Section)*.
This report is a reconstructed analysis of the guide's simulated dataset for SOC training purposes.